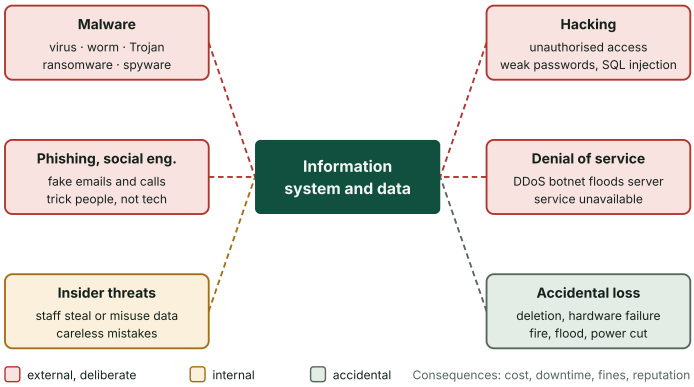
Threats to data, archiving and the need for backup

AP14 FACT FILE

Specification: students should be able to

- Describe the main deliberate threats to data: malware (viruses, worms, Trojans, ransomware and spyware), hacking, social engineering and denial of service
- Describe internal and accidental threats, including insider misuse, human error, hardware failure and natural disasters, and their consequences for organisations
- Explain why data is archived, including the advantages and disadvantages of archiving
- Explain the difference between archiving data and backing up data
- Explain the need for backup and recovery, including the use of restore points

Key words: malware, virus, worm, Trojan, ransomware, spyware, hacking, phishing, social engineering, distributed denial of service (DDoS), insider threat, active data, inactive data, data archiving, backup, data recovery, restore point, transaction log



Threats to an information system grouped as external deliberate attacks, insider threats and accidental loss

Overview: threats to data and why recovery matters

Every organisation, from a corner shop in Omagh to a health trust in Belfast, depends on its data. That data faces two broad kinds of threat. Deliberate threats include malicious software, hacking, social engineering, denial of service attacks and insiders who misuse the access they have been given. Accidental threats are at least as common: staff delete or overwrite files, hardware fails, power is lost, and buildings suffer fire or flooding. The consequences of losing data, or of having it stolen, include lost income, time when systems cannot be used, regulatory action by the Information Commission (formerly the ICO) under the UK GDPR and Data Protection Act 2018, and loss of customer trust. Because no organisation can remove every risk, good practice has two parts. The first is to reduce the likelihood of loss through security measures. The second is to make sure that, when loss happens anyway, data can be recovered quickly. This lesson covers the threats, explains how inactive data is archived so it is retained safely without slowing the live system, and explains why current data must be backed up and how a restore point is used during recovery.

Malware

Malware is any software written to damage, disrupt or gain unauthorised access to a system. The types are best told apart by how they spread and what they do. A virus attaches itself to a host file or program and spreads when that host is run or shared, so it needs some user action. A worm is a standalone program that copies itself across a network on its own, usually by exploiting a vulnerability that has not been patched, and can spread very quickly while consuming bandwidth. A Trojan pretends to be legitimate software, such as a free game or a fake invoice viewer, and the user installs it willingly; it does not replicate but delivers a hidden payload such as a back door that gives an attacker remote control. Ransomware encrypts the victim's files and demands payment, often in cryptocurrency, for the key; paying gives no guarantee of recovery, which is why recent, separate backups are the best defence. Spyware, including keyloggers, secretly records activity such as keystrokes, websites visited or passwords and sends the information to the attacker.

Hacking, social engineering and denial of service

Hacking means gaining unauthorised access to a computer system or the data on it. Under the Computer Misuse Act 1990, as amended, simply accessing material without permission is an offence, and further offences cover access with intent to commit other crimes and impairing the operation of a system. Hackers look for unpatched software, weak or reused passwords that can be cracked by brute-force or dictionary attacks, and web forms that do not validate input and so allow SQL injection. Social engineering attacks the person rather than the technology. Phishing emails imitate a bank, delivery firm or the organisation's own IT department to persuade users to enter credentials on a fake site; spear phishing is tailored to one individual, smishing uses text messages and vishing uses phone calls. These attacks exploit trust, urgency and fear, so awareness training is essential. A denial of service attack overwhelms a server with traffic so that genuine users cannot reach it. A distributed attack uses a botnet of compromised devices, making it much harder to filter out, and its main harm is lost availability rather than stolen data.

Internal and accidental threats

Many incidents start inside the organisation. A malicious insider, such as an employee who has been dismissed or is joining a competitor, may copy, alter or delete data using access they legitimately hold, which makes the activity harder to spot. Careless insiders cause even more breaches: sending a spreadsheet to the wrong email address, leaving an unencrypted laptop on a train, or clicking a phishing link. Accidental threats also include human error such as saving over a file or deleting a folder, hardware failure such as a disk crash, power cuts and surges, and environmental events such as fire or flooding. When personal data is involved, a breach that risks harm to individuals must normally be reported to the Information Commission within 72 hours of the organisation becoming aware of it. In an answer about consequences, always apply them to the scenario: a hospital might be unable to see test results, a council might miss benefit payments, and a sports club might lose its fixture and membership lists just before the season starts.

Archiving inactive data

Organisations hold active data, which is needed immediately for daily work, and inactive data, which is rarely used but must still be kept. A further education college needs instant access to current students' timetables, attendance and fees, but former students' records are needed only occasionally, for references, audits or legal requirements. Data archiving is the process of moving such inactive data out of the live system into separate, secure, long-term storage. The archive must be indexed so that records can be located again, and the data must be complete and suitably structured so that it is meaningful years later. The main advantages are that the live system holds far fewer records, so processing, reporting and backups are faster; older data is retained for reference and compliance; and cheaper, slower storage can be used. The disadvantages are that archived data is not instantly available, time must be spent searching for it, and access may be slow once it has been found. Archived personal data is still covered by the UK GDPR, so it should be kept only for a defined retention period and then securely deleted.

Backup, recovery and restore points

Backing up is a different activity from archiving. Archiving moves inactive data away for long-term retention, whereas a backup is a copy of current data, taken regularly and stored separately, so that the live system can be rebuilt if data is corrupted, deleted or destroyed. Because losing current data hits an organisation immediately, backups are a high priority and are normally automated, perhaps nightly or even several times an hour for critical systems such as online booking. Data recovery is the process of using backed-up data to return a system to an earlier correct state. A restore point captures the exact state of the system when a backup was taken, so recovery can return the system exactly to that state. Anything that changed after the restore point would be lost, unless the changes were also recorded elsewhere. Many database systems keep a transaction log; after restoring the latest backup, the logged transactions are re-applied in order, rolling the data forward to just before the failure. The gap between backups therefore determines how much work is at risk.

Key terms from the mark schemes

Malware
Malicious software, such as viruses, worms, Trojans, ransomware and spyware, written to damage or disrupt systems or to gain unauthorised access to data.
`Credited: malicious software`

Worm
Standalone malware that replicates itself across a network without needing a host file or any user action, usually by exploiting unpatched vulnerabilities.

Trojan
Malware disguised as legitimate software that the user installs; it carries a hidden harmful payload such as a back door and does not self-replicate.
`Credited: Trojan horse`

Ransomware
Malware that encrypts a victim's files and demands payment in exchange for the decryption key.

Phishing
A social engineering attack using fraudulent emails, messages or websites that imitate trusted organisations to trick people into revealing personal details.

Social engineering
Manipulating people into giving away confidential information or access, rather than attacking the technology directly.

Distributed denial of service (DDoS)
An attack in which many compromised devices flood a server or network with requests so that legitimate users cannot access it.
`Credited: DDoS attack`

Insider threat
A risk to data posed by people inside an organisation, such as employees or contractors, who misuse their legitimate access deliberately or carelessly.

Data archiving
Moving inactive data that is no longer needed for daily use from the live system to separate, secure long-term storage, indexed so it can be retrieved later.
`Credited: archiving`

Inactive data
Data that is no longer needed for day-to-day operations but must be kept for reference, audit or legal reasons.
`Credited: historical data`

Data recovery
Using backed-up data to restore a system to a previously correct state after data has been lost or corrupted.

Restore point
A record of the state of a system at the precise moment it was backed up, allowing the system to be returned to that state.

Exam focus

Questions on this lesson tend to use State or List for one-mark points, Describe or Explain for two to four marks, and an extended question of six marks or more set in a scenario. For malware, make the distinguishing feature explicit: a worm spreads by itself across a network, a virus needs a host file and user action, and a Trojan is disguised and does not replicate. For archiving, a definition worth full marks says that inactive data is moved to separate secure storage and can still be retrieved later, ideally through an index. Advantages and disadvantages earn most credit when applied: say that reports on the supermarket's or club's live data would run faster, not just that the system improves. A common mistake is to treat archiving and backup as the same thing; remember that archiving moves inactive data out, while backing up copies current data that stays in the live system. When asked about a restore point, say what it records and that the system is restored to that state, then mention re-applying transactions logged since. In extended answers, cover a range of points and reach a judgement linked to the context.

? Check yourself

1. Describe the difference between a virus and a worm. [2]
2. A member of staff at a Lisburn engineering firm installs a free PDF tool that turns out to be a Trojan. Describe how the Trojan could harm the firm. [3]
3. Explain what is meant by phishing and describe two features that may help a user recognise a phishing email. [3]

Answers: 1. A virus attaches to a host file and needs the user to run or share it to spread (1) / a worm is standalone and self-replicates across a network without user action (1). 2. Any three from: it is disguised as legitimate software so the user installs it willingly (1) / it may open a back door giving an attacker remote access (1) / it may install spyware or a keylogger to steal passwords or designs (1) / it may download ransomware that encrypts the firm's files (1) / leading to loss of data, downtime or a data breach (1). 3. Phishing is a fraudulent email or message pretending to come from a trusted organisation (1) to trick the user into revealing personal details such as passwords or bank details (1). Any one feature for 1 mark, max 3 total: urgent or threatening tone / generic greeting / sender address or link that does not match the real organisation / spelling and grammar errors / request for login or payment details / unexpected attachment.